Data Classification and Handling Policy

Policy ID: IT-SEC-005 | Version 2.0 | Owner: Data Protection Office | Effective: 1 March 2026

1. Classification Levels

- Public: approved for release, for example marketing pages and published blog posts.
- Internal: the default level for company information, such as org charts, internal wiki pages and meeting notes.
- Confidential: information that could harm Kestrel or its customers if disclosed, such as contracts, pricing, unreleased financial results and non-public source code.
- Restricted: the most sensitive data, including customer personal data, payment card data, health data, credentials, encryption keys and security vulnerability reports.

If you are unsure, treat the data as Confidential and ask the data owner.

2. Where Data May Be Stored

Restricted data may be stored only in approved systems: the production data platform, restricted SharePoint sites and the secrets vault. It must never be kept on a laptop outside an approved encrypted folder, in personal cloud storage or in email attachments. Confidential data may be stored in company SharePoint, OneDrive and approved SaaS tools.

3. Sharing With External Parties

Confidential data may be shared outside the company only when a signed NDA is in place, using SharePoint links that expire after 30 days. Restricted data may be shared externally only with written approval from the Data Protection Officer, and only through encrypted transfer (SFTP or the secure file share). Never send Restricted data as an email attachment.

4. Removable Media

USB storage devices are blocked on company laptops by default. An exception needs a request approved by your manager and by Information Security, and only company-issued encrypted USB drives may be used. Exceptions expire after 90 days.

5. Retention and Disposal

Keep data only as long as the retention schedule requires. Customer data is deleted within 90 days of the end of a contract unless the contract says otherwise. Paper containing Confidential or Restricted data goes in the locked shredding bins, and old drives are destroyed by the IT asset team, which issues a certificate of destruction.

6. Data Breaches

Report any suspected data breach, such as data sent to the wrong person, a lost unencrypted device or data exposed publicly, within 1 hour as a Security Incident. The Data Protection Officer decides whether regulators and customers must be told. Where notification is required, regulators are notified within 72 hours of discovery.